

P-SGSI-03: Marco de Respuesta Dinámica ante Incidentes de Seguridad (CSIRT-UNCP)

Universidad Nacional del Centro del Perú (UNCP)

SGSI ISO/IEC 27001:2022

Organización: Universidad Nacional del Centro del Perú (UNCP) **Versión:** 1.0 (Enfoque DevSecOps) **Norma:** ISO/IEC 27001:2022 (Controles A.5.24 - A.5.28) **Alineamiento:** PGTD-06 (Sistema de Gestión de Incidentes)

1. Propósito y Enfoque Ágil

Este procedimiento establece un ciclo de vida dinámico para la detección, reporte, respuesta y aprendizaje ante incidentes de seguridad. A diferencia de los métodos tradicionales, la UNCP adopta un enfoque de **Monitoreo Continuo**, donde la detección es automatizada y la respuesta se basa en *playbooks* (guías de acción rápida) para minimizar el impacto en los servicios académicos y administrativos.

2. El Ciclo de Vida del Incidente (Enfoque PHVA Dinámico)

2.1. Planificar (Preparación y Visibilidad)

- **Telemetría Total:** Se integra la captura de tráfico mediante TAP físicos y NetFlow (Anexo H.2 del PGTD) para tener visibilidad de “línea de base” de la red universitaria.
- **SIEM Universitario:** Centralización de logs de Huawei Cloud, ERP ADESA y Moodle en el SIEM (Wazuh/Sentinel) para detectar anomalías en tiempo real.
- **Canales de Reporte:**
 - **Automático:** Alertas generadas por el SIEM.
 - **Manual:** Portal de auto-servicio para la comunidad universitaria y correo `incidentes-seguridad@uncp.edu.pe`.

2.2. Hacer (Detección y Respuesta Ágil)

Ante una alerta, se activa el CSIRT (Computer Security Incident Response Team) de la OTI bajo los siguientes pasos: 1. **Triage y Categorización:** Clasificación inmediata (Baja, Media, Alta, Crítica) según el impacto en la disponibilidad del Campus Virtual o integridad de notas. 2. **Contención Inmediata (Shift Left):** Si se detecta un ataque DDoS o inyección SQL, el WAF (Huawei Cloud) o el API Gateway deben aplicar reglas de bloqueo automáticas antes de la intervención humana. 3. **Erradicación y Recuperación:** Limpieza de sistemas afectados y restauración de servicios mediante el uso de contenedores y *snapshots* de nube.

2.3. Verificar (Monitoreo y Análisis de Datos)

- **Dashboards de Seguridad:** Visualización en tiempo real del estado de los incidentes.
- **Indicadores de Gestión (KPIs):**
 - **MTTD (Tiempo Medio de Detección):** Meta < 2 horas para incidentes críticos.
 - **MTTR (Tiempo Medio de Respuesta):** Meta < 24 horas para resolución.
- **Análisis Forense Ágil:** Identificación de la causa raíz mediante el análisis de logs centralizados.

2.4. Actuar (Optimización y Prevención)

- **Lecciones Aprendidas:** Reunión de “post-mortem” después de incidentes Críticos/Altos para ajustar la configuración de seguridad.
- **Actualización de Playbooks:** Si un incidente reveló una vulnerabilidad nueva, se actualizan las reglas del Firewall/WAF inmediatamente para evitar recurrencia.

3. Clasificación de Impacto para la UNCP

Nivel	Ejemplo de Incidente	Acción Requerida
Crítico	Alteración de notas en ERP ADESA o caída total de red durante matrícula.	Activación inmediata del CGD y respuesta en < 1 hora.
Alto	Infección masiva por Ransomware en una facultad.	Aislamiento de red (VLAN) y recuperación de backups.
Medio	Phishing dirigido a correos institucionales.	Bloqueo de remitente y reseteo de contraseñas masivo.
Bajo	Escaneo de puertos sin éxito desde IP externa.	Monitoreo y registro en el SIEM.

4. Responsabilidades

- **Oficial de Seguridad:** Liderar el CSIRT y coordinar con el Centro Nacional de Seguridad Digital (PCM).
- **Equipo OTI (DevOps):** Implementar las reglas técnicas de contención y recuperación de servicios.
- **Usuarios:** Reportar actividades sospechosas de forma temprana.

Este documento es una guía dinámica y se actualiza trimestralmente según la evolución de las amenazas detectadas.